

Day 33 – Advanced Investigation Challenge

Scenario Overview

At 02:14 AM, multiple security alerts were triggered indicating a possible compromise of the network.

Alerts Observed

1. Multiple **Event ID 4625** Failed Login Attempts
 - a. Source IP: **185.23.44.91**
2. Successful login for **backup_admin**
3. **PowerShell** executed using an encoded command
4. New local administrator account created
5. Outbound connection to **45.77.122.18**
6. **3.5 GB** of data transferred outside the network

1. Initial Incident Summary

The investigation indicates a likely successful compromise through a brute-force or credential attack. After obtaining valid credentials, the attacker executed malicious PowerShell commands, escalated privileges by creating a new administrator account, established external communication, and exfiltrated a large volume of data from the network.

2. Attack Timeline

Time	Activity
02:14 AM	Multiple failed login attempts detected (Event ID 4625)
02:16 AM	Successful login using backup_admin account
02:18 AM	Encoded PowerShell command executed
02:20 AM	New local administrator account created
02:24 AM	Connection established to 45.77.122.18
02:35 AM	3.5 GB data transferred outside network

3. Possible Attack Chain

Initial Access

Attacker performs brute-force/password-spraying attack against exposed services.

Credential Access

Valid credentials for **backup_admin** obtained.

Execution

Encoded PowerShell command executed to bypass detection and run malicious scripts.

Privilege Escalation

Creation of a new administrator account for persistence and elevated access.

Command & Control (C2)

System communicates with external IP address.

Exfiltration

Sensitive organizational data transferred outside the network.

4. MITRE ATT&CK Mapping

Tactic	Technique
Initial Access	Password Spraying (T1110.003)
Credential Access	Brute Force (T1110)
Execution	PowerShell (T1059.001)
Persistence	Create Account (T1136)
Privilege Escalation	Account Manipulation (T1098)
Command & Control	Application Layer Protocol (T1071)
Exfiltration	Exfiltration Over C2 Channel (T1041)

5. Indicators of Compromise (IOCs)

Suspicious IP Addresses

- 185.23.44.91
- 45.77.122.18

User Accounts

- backup_admin
- Newly created administrator account

Activities

- Multiple failed login attempts
- Encoded PowerShell execution
- Unauthorized admin account creation
- Large outbound data transfer

6. Risk Assessment

Risk Level: Critical

Impact

- Credential compromise
- Privilege escalation
- Data theft
- Potential persistence mechanism established

Business Impact

- Loss of confidential data
- Regulatory compliance issues
- Financial and reputational damage

7. Containment Actions

Immediate Actions

- Block IP addresses:
 - 185.23.44.91
 - 45.77.122.18
- Disable compromised accounts
- Remove unauthorized administrator account
- Isolate affected systems from the network

Further Actions

- Reset passwords for privileged accounts
- Conduct malware and persistence hunting
- Review PowerShell logs
- Perform full endpoint forensic analysis

8. Detection Opportunities

SIEM Use Cases

- Excessive Event ID 4625 failures
- Successful login after multiple failures
- Encoded PowerShell execution detection
- New administrator account creation
- Large outbound data transfers
- Connections to known malicious IPs

Recommended Monitoring

- Windows Security Logs
- PowerShell Operational Logs

- EDR Alerts
- Network Traffic Analysis
- User Behavior Analytics (UEBA)

9. Executive Summary

A threat actor successfully compromised the **backup_admin** account after multiple failed login attempts. Following access, malicious PowerShell commands were executed and a new administrator account was created, indicating privilege escalation and persistence. The attacker then communicated with an external host and exfiltrated approximately **3.5 GB** of data. Immediate containment and forensic investigation are required to prevent further compromise.

10. Final Verdict

Incident Classification

Confirmed Security Breach

Attack Type

- Brute Force / Password Spraying
- Privilege Escalation
- Command & Control Activity
- Data Exfiltration

Severity

Critical (High Business Impact)

Conclusion

The evidence strongly suggests a successful cyber intrusion resulting in unauthorized access, privilege escalation, external communication, and data exfiltration. Immediate containment, credential reset, forensic investigation, and enhanced monitoring are necessary to mitigate the threat and prevent recurrence.

Key Learning Points

- Monitor Event ID 4625 login failures.
- Detect encoded PowerShell execution.
- Track privileged account creation.
- Alert on abnormal outbound data transfers.
- Correlate authentication, endpoint, and network logs for rapid incident response.